UNINASSAU
Campus Boa Viagem

Disciplina: Laboratório de Empreendimentos Inovadores

Plano de Gerenciamento de Riscos e Aquisições

Prof. Pedro Rodolfo Gomes de Souza
eu@prgsouza.com.br

Objetivos de Aprendizagem

Riscos no PMBOK: Diferenciar causa, risco (incerteza futura) e problema/issue (fato presente).

Análise Qualitativa e Quantitativa: Priorizar na matriz P×I e calcular Valor Monetário Esperado (VME).

Estratégias de Resposta: Aplicar respostas para ameaças e oportunidades com reservas calibradas.

Decisão Make-or-Buy: Avaliar desenvolver internamente vs. contratar SaaS, nuvem ou fábrica.

Contratos e Fornecedores: Dominar Preço Fixo, Tempo e Material, SLAs, SOW e mitigação de Lock-in.

ABERTURA • CONEXÃO ESTRATÉGICA

Por Que Riscos e Aquisições Andam Juntos em ADS?

UNINASSAU
Campus Boa Viagem

Incerteza Técnica

Integrações e APIs concentram ameaças.

Transferência

Contratos transferem riscos a terceiros.

Risco Contratual

Fornecedor ruim cria novos riscos.

Governança SLA

Métricas protegem operação em nuvem.

O Custo da Incerteza Ignorada em TI

70%

Dos projetos falham por riscos óbvios não tratados

Gestão de Bombeiro: Ignorar alertas na fase inicial e apagar incêndios na véspera do deploy.

Terceirização Cega: Contratar fábrica de software sem especificação clara (SOW) nem critérios de aceite.

Dependência Externa: Assumir que APIs de terceiros e gateways funcionarão de primeira.

Riscos e Aquisições no PMBOK 6ª, 7ª e 8ª Edições

Dimensão	PMBOK 6ª Edição (Processos)	PMBOK 7ª e 8ª Edições (Valor e Domínios)
Riscos	Planejar, Identificar, Analisar (Quali/Quanti), Responder e Monitorar	Domínio da Incerteza, resiliência, antifragilidade e spikes ágeis
Aquisições	Planejar, Conduzir e Controlar Aquisições	Parcerias orientadas a valor, contratos ágeis e ecossistema SaaS
Integração	Reservas no orçamento e cláusulas no contrato	Governança adaptativa contínua entre time interno e parceiros

Tailoring em Riscos e Contratações

Projeto Acadêmico / MVP: Top 5 riscos no quadro Kanban, spikes técnicos e uso de PaaS gratuito.

Software Corporativo: Registro de riscos quinzenal, matriz P×I, SLA de nuvem e contrato T&M com teto.

Setor Público / Bancário: Análise quantitativa VME, edital RFP formal, contrato de preço fixo e auditoria.

Regra Prática: O rigor do controle deve ser proporcional ao impacto financeiro e reputacional.

Roteiro dos 8 Módulos

Módulos	Temas Centrais
Módulos 1 e 2	Fundamentos de Risco, Causa-Risco-Efeito, RBS, Registro de Riscos e Matriz P×I
Módulos 3 e 4	Análise Quantitativa (VME), Estratégias de Resposta, Reservas e Monitoramento
Módulos 5 e 6	Planejar Aquisições, Análise Make-or-Buy, SOW, RFP e Tipos de Contrato (FP vs T&M)
Módulos 7 e 8	Seleção de Fornecedores, SLA, Cloud/SaaS, Lock-in e Oficina Integrada

MÓDULO 01

Fundamentos e Planejamento dos Riscos

Incerteza, ameaças, oportunidades e estrutura analítica de riscos (EAR/RBS).

O Que é Risco no PMBOK? (Ameaças e Oportunidades)

Evento Incerto
Condição futura que pode ou não ocorrer.



Ameaça (Negativo)
Atraso de API, queda de servidor ou multa.



Oportunidade (Positivo)
Reuso de componente que antecipa entrega.



Causa vs. Risco (Incerteza) vs. Problema (Issue)

Conceito	Natureza Temporal	Exemplo no Projeto FinTech EduPay
Causa (Fato Atual)	Condição existente que gera incerteza	Apenas 1 dev conhece a API do Banco Central
Risco (Futuro Incerto)	Evento que pode ocorrer (Prob. < 100%)	**Se** o dev adoecer, **podemos** atrasar o PIX em 3 semanas
Efeito (Impacto)	Consequência caso o risco se materialize	Multa contratual de R$ 15 mil e perda do semestre
Problema / Issue (100%)	Já aconteceu; exige ação imediata	O servidor de homologação caiu hoje pela manhã

Exercício 1: Risco, Causa ou Problema (Issue)?

Frase 1: "O ambiente de testes está fora do ar desde ontem." → **Problema / Issue** (já ocorreu, vai para o Issue Log).

Frase 2: "A documentação da API legada está desatualizada." → **Causa / Fato** (condição presente que alimenta risco).

Frase 3: "Devido à documentação ruim, a integração pode exigir retrabalho e atrasar 10 dias." → **Risco** (incerteza futura estruturada).

Frase 4: "Faltam 2 desenvolvedores na equipe atual." → **Problema / Restrição** de recursos atual.

Plano de Gerenciamento dos Riscos e EAR (RBS)

Riscos Técnicos

Arquitetura, APIs, performance e segurança.

Riscos Externos

Fornecedor cloud, câmbio, LGPD e cliente.

Organizacionais

Corte de verba, perda de dev e prioridades.

Gestão de Projeto

Estimativas ruins, escopo vago e comunicação.

Caso 1: A API Bancária Sem Sandbox no EduPay

Contexto: Equipe precisa integrar geração de boleto e PIX em 8 semanas, mas o banco parceiro só libera ambiente de testes na Semana 6.

Apetite a Risco: A faculdade tem tolerância zero a erro em valores cobrados dos alunos.

Decisão de Planejamento: Classificar integração como risco crítico técnico/externo desde o Dia 1.

Ação Preventiva: Construir servidor Mock baseado na especificação técnica na Semana 2.

MÓDULO 02

Identificação e Análise Qualitativa de Riscos

Metaliguagem de riscos, registro oficial e matriz de probabilidade e impacto.

Como Escrever um Risco: Metaliguagem Estruturada

DEVIDO A (Causa) → PODE OCORRER (Evento) → GERANDO (Impacto)

Errado (Vago): "Risco de banco de dados" ou "Risco de atrasar os testes".

Correto (Acionável): "**Devido à** ausência de índices nas tabelas legadas, **a consulta de matrícula pode** exceder 10s no pico, **gerando** queda do portal no primeiro dia."

O Registro de Riscos (Risk Register)

ID	Evento de Risco	Gatilho (Trigger)	P × I	Dono do Risco
R-01	Instabilidade na API de PIX externo	Latência > 3s em homologação	Alta × Alto	Arquiteto Backend
R-02	Saída do único dev especialista em React	Atraso em PRs e propostas externas	Média × Alto	Líder Técnico
R-03	Vazamento de dados pessoais em log	Alerta do scanner SAST no pipeline	Baixa × Muito Alto	Analista Segurança
R-04	Reuso de biblioteca UI pronta (Oportunidade)	Aprovação do protótipo na Sem. 1	Alta × Médio	Líder Frontend

Urgência, Proximidade e Qualidade dos Dados

Proximidade

Risco na Sprint 1 exige ação imediata.

Detectabilidade

Falha silenciosa de cálculo é mais grave.

Impacto Estratégico

Multa LGPD supera custo técnico direto.

MÓDULO 03

Análise Quantitativa e Respostas aos Riscos

Valor Monetário Esperado (VME), árvore de decisão e estratégias de resposta.

Valor Monetário Esperado (VME / EMV) e Contingência

$$\text{VME} = \text{Probabilidade (\%)} \times \text{Impacto Financeiro (R\$)}$$

Convenção de Sinal: Ameaças geram VME negativo (custo adicional); Oportunidades geram VME positivo (economia).

Dimensionamento da Reserva: A soma algébrica dos VMEs define a **Reserva de Contingência** exata da Linha de Base.

Exercício 3: Calcule a Reserva de Contingência via VME

ID e Risco Mapeado	Tipo	Probabilidade	Impacto (R$)	VME Calculado
R-01: Retrabalho na integração PIX	Ameaça	40%	– R$ 30.000	**– R$ 12.000**
R-02: Multa por atraso de homologação	Ameaça	25%	– R$ 20.000	**– R$ 5.000**
R-03: Uso de template pronto de relatórios	Oportunidade	50%	+ R$ 8.000	**+ R$ 4.000**
RESERVA DE CONTINGÊNCIA LÍQUIDA	**Soma VME**	—	—	**– R$ 13.000 (Reservar R$ 13 mil)**

As 5 Estratégias para Ameaças (Riscos Negativos)

1. Prevenir (Avoid)

Elimina a causa ou corta o requisito arriscado.

2. Mitigar (Mitigate)

Reduz probabilidade ou impacto via POC/testes.

3. Transferir

Passa a terceiro via seguro, SaaS ou contrato.

4. Aceitar / Escalar

Reserva contingência ou sobe ao patrocinador.

As 5 Estratégias para Oportunidades (Riscos Positivos)

Estratégia	Objetivo	Exemplo Prático em Software
Explorar (Exploit)	Garantir 100% que a oportunidade ocorra	Alocar o arquiteto sênior para reutilizar o motor de autenticação pronto
Melhorar (Enhance)	Aumentar probabilidade ou ganho	Automatizar deploy para ganhar 3 dias extras na janela de testes
Compartilhar (Share)	Unir forças com parceiro externo	Co-desenvolver plugin acadêmico com outra universidade dividindo custos
Aceitar / Escalar	Aproveitar se vier sem custo extra	Receber desconto espontâneo de créditos educacionais na AWS

Exercício 4: Classifique a Estratégia de Resposta

Ação 1: Desistir de criar gateway próprio de cartão e contratar Stripe/MercadoPago com SLA → **Transferir** (e Prevenir risco PCI interno).

Ação 2: Realizar teste de carga e configurar auto-scaling antes do dia da matrícula → **Mitigar**.

Ação 3: Remover o módulo experimental de reconhecimento facial do MVP → **Prevenir (Eliminar)**.

Ação 4: Separar R$ 5 mil na reserva para horas extras caso a homologação atrase → **Aceitação Ativa**.

MÓDULO 04

Monitoramento de Riscos e Riscos em Ágil

Riscos residuais, secundários, planos de fallback, spikes e burndown de risco.

Risco Residual, Risco Secundário e Plano de Fallback

Risco Residual

Sobra após a mitigação (ex: 5% de chance).

Risco Secundário

Novo risco criado pela própria resposta.

Plano de Contingência

Ação disparada pelo gatilho (Trigger).

Plano de Contorno

Workaround improvisado para risco não previsto.

Gestão de Riscos em Projetos Ágeis: Spikes e Risk-Adjusted Backlog

Backlog Ajustado ao Risco: Priorizar histórias que combinam alto valor de negócio e alto risco técnico logo nas Sprints 1 e 2 (*Fail Fast*).

Spike Técnico: Experimento curto com tempo fixo (24h–48h) para testar integração incerta antes de estimar a release.

Risk Burndown Chart: Gráfico que mostra a queda da exposição total a riscos a cada sprint concluída.

Caso 2 (Risco Secundário): Contratar WAF externo para mitigar ataque DDoS gerou risco secundário de bloquear IPs legítimos da secretaria.

MÓDULO 05

Fundamentos de Aquisições e Decisão Make-or-Buy

Planejar contratações, desenvolver vs. comprar, SaaS/Cloud e documentos SOW/RFP.

O Que São Aquisições em Projetos de Software?

Infra Cloud (IaaS/PaaS)

AWS, Azure, GCP, banco gerenciado e CDN.

APIs e SaaS

Auth0, Stripe, SendGrid, Firebase e ERPs.

Outsourcing / Squads

Fábricas de software e consultorias UX/Sec.

Papéis Legais

Comprador (Cliente) vs. Fornecedor (Vendor).

Análise Fazer ou Comprar (Make-or-Buy) em ADS

Critério de Decisão	Quando Desenvolver (Make)	Quando Comprar / Assinar SaaS (Buy)
Core Business	Diferencial competitivo exclusivo do negócio	Commodity padronizada (ex: login, gateway, e-mail)
Prazo (Time-to-Market)	Janela folgada para construir e maturar	Urgência alta para lançar MVP funcional
Competência e Segurança	Equipe domina tecnologia internamente	Exige certificação complexa (ex: PCI-DSS, biometria)
Custo Total (TCO)	Escala massiva dilui custo fixo de criação	Menor custo inicial e manutenção inclusa na assinatura

MÓDULO 06

Tipos de Contratos e Alocação de Riscos

Preço Fixo (FFP, FPIF), Tempo e Material (T&M) e Custos Reembolsáveis.

As 3 Famílias de Contratos no PMBOK

Tipo de Contrato	Quando Usar em Software	Quem Assume o Risco de Custo?
Preço Fixo (FFP / FPIF)	Escopo fechado, requisitos claros e estáveis	**Fornecedor**
Tempo e Material (T&M)	Alocação de devs/squads e escopo ágil evolutivo	**Comprador**
Custo Reembolsável (CPFF/CPIF)	Pesquisa e Desenvolvimento (P&D) de alta incerteza	**Comprador** (paga custos reais auditados + taxa)

Contratos em Projetos Ágeis de Software

Armadilha do Triângulo Invertido: Contrato de Preço Fixo + Prazo Fixo + Escopo Fixo gera litígio quando requisitos mudam.

Preço Fixo por Sprint / Iteração: Cliente contrata capacidade fixa por sprint e pode repriorizar o backlog a cada ciclo.

Cláusula Money for Nothing: Permite encerrar o contrato antecipadamente se o MVP já atingiu 100% do valor de negócio esperado.

Cláusula Change for Free: Permite trocar uma história futura por outra de mesmo tamanho (story points) sem aditivo burocrático.

Exercício 6: Escolha o Contrato Ideal para Cada Cenário

Situação de Contratação em TI	Contrato Recomendado e Justificativa
1. Migração de 50 telas legadas já documentadas e congeladas	**Preço Fixo Fechado (FFP):** Escopo 100% conhecido e auditável
2. Contratação de 2 especialistas DevOps por 3 meses para apoiar time	**Tempo e Material (T&M) com teto:** Paga horas trabalhadas até limite
3. Desenvolvimento de novo app inovador com backlog aberto	**Contrato Ágil por Releases / Sprints Fixas:** Protege adaptação
4. Compra de 200 licenças anuais de antivírus corporativo	**Ordem de Compra / Preço Fixo via RFQ:** Produto de prateleira

MÓDULO 07

Conduzir e Controlar Aquisições, SLAs e Cloud

Seleção multicritério de fornecedores, acordos de nível de serviço (SLA) e Vendor Lock-in.

Conduzir Aquisições: Matriz Ponderação de Fornecedores

Critério (Peso)	Fornecedor Alpha	Fornecedor Beta	Fornecedor Gamma
Capacidade Técnica (40%)	9,0 (3,60)	6,0 (2,40)	8,0 (3,20)
Preço Comercial (30%)	7,0 (2,10)	9,5 (2,85)	7,5 (2,25)
Segurança e LGPD (20%)	9,5 (1,90)	5,0 (1,00)	8,0 (1,60)
Referências Anteriores (10%)	8,0 (0,80)	6,0 (0,60)	7,0 (0,70)
NOTA FINAL PONDERADA	**8,40 (Vencedor)**	6,85 (Barato mas frágil)	7,75 (2º Colocado)

Controlar Aquisições: SLA, SLO, SLI e Penalidades

SLI (Indicador)

Métrica aferida (ex: latência P95 = 1,4s).

SLO (Objetivo)

Meta técnica (ex: uptime mensal ≥ 99,9%).

SLA (Contrato)

Acordo jurídico com multa ou crédito se violar.

Propriedade (IP)

Código-fonte e repositório pertencem ao cliente.

Vendor Lock-in, Shadow IT e Segurança de Terceiros

Vendor Lock-in: Dependência extrema de tecnologia proprietária que torna caro trocar de fornecedor.

Como Mitigar Lock-in: Usar containers (Docker), padrões abertos (PostgreSQL, OpenAPI) e camada de abstração (*Adapter Pattern*).

Shadow IT: Equipe assina SaaS no cartão corporativo sem passar por revisão de segurança ou arquitetura.

Cláusula de Transição (Exit Plan): Contrato deve obrigar fornecedor a transferir dados e conhecimento no encerramento.

Exercício 7 e Caso 3: Crise com Fábrica de Software

Cenário (SmartCampus): Fábrica contratada por Preço Fixo entrega módulo de catraca sem testes, recusa pequenos ajustes alegando "mudança de escopo" e retém o código-fonte no Git privado dela.

Falha de Aquisição 1: SOW não exigiu repositório no Git da própria faculdade nem critérios de Definition of Done (DoD).

Falha de Aquisição 2: Pagamento atrelado a datas do calendário em vez de entregas homologadas.

Ação Corretiva: Condicionar pagamento da parcela ao aceite em homologação, exigir transferência imediata do repositório e formalizar rito de mudanças.

Checklist de Revisão para Prova e Referências

Referências Base: PMI (PMBOK Guide 6ª, 7ª e 8ª ed., 2025); PMI (The Standard for Risk Management, 2019).

Referências Software: Sommerville (Engenharia de Software, 10ª ed.); Kerzner (2015); Xavier et al. (Methodware).

UNINASSAU
Campus Boa Viagem

Disciplina: Laboratório de Empreendimentos Inovadores

Plano de Gerenciamento de Riscos e Aquisições

Prof. Pedro Rodolfo Gomes de Souza
eu@prgsouza.com.br